NORDLYS
TECHNOLOGIES

ISO/IEC 27001:2022 | Clause 4

Information Security Management System Scope

Information Security Management System Scope

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review
2026.10.11	1.0	Cyber Security GRC Analyst	Initial release of the ISMS scope	CEO	2026.10.11	Annual	2027.10.11

Purpose

This document defines the scope of the Information Security Management System (ISMS) at Nordlys Technologies, in line with ISO/IEC 27001:2022. It describes where the ISMS applies and where it does not, and takes into consideration the company's context, its business objectives and the requirements of its interested parties.

The scope is intended to make sure that information security risks are identified and managed consistently across the environment in which Nordlys processes employee and payroll data for its customers. It supports the company's commitment to protecting the confidentiality, integrity and availability of the information handled through its Software-as-a-Service (SaaS) payroll and HR platform, Nordlys Payroll & People.

Scope Statement

The ISMS covers the Nordlys Payroll & People platform, from development through to day-to-day operation and customer support. The platform is a cloud-based service used by around 220 small and mid-sized businesses in Norway, Sweden and Denmark for employee records, absence, time registration and payroll, including the payment files we send to customers' banks.

Everything needed to deliver that service is inside the boundary: the people who build and run it, the development, test and production environments on AWS in the EU, the internal tools they use, and the suppliers we rely on.

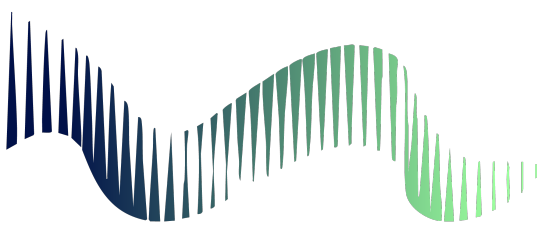
In Scope

Area	Included
Service	Nordlys Payroll & People platform (multi-tenant web application, APIs and the employee mobile app)
Locations	Head office in Oslo, the Bergen office, and wherever staff work remotely
Infrastructure	AWS production, staging and development accounts (primary region Stockholm eu-north-1, disaster recovery in Frankfurt eu-central-1); containerised services, PostgreSQL databases and S3 storage; the CI/CD pipeline and source code repositories in GitHub
People	Employees, contractors and consultants who can reach the platform, its data or the systems behind it
Information	Customer employee personal data, including salary data, national ID numbers (fødselsnummer) and bank account numbers; customer contracts; source code; credentials and cryptographic keys; support tickets; operational logs
Supporting Systems	Microsoft 365 and Entra ID, the MFA service, Intune-managed devices, Jira, and logging and monitoring (CloudWatch plus a managed log service)

Out of Scope

Area	Excluded and Why
Corporate Finance and Accounting	Our own bookkeeping is done by an outside accountant and holds no customer employee data. Handled through supplier management instead.
Public marketing website	Static pages, hosted separately. No customer or personal data.
Customer environments	Customers look after their own networks, devices and systems. We only secure the point where they connect to our platform.

Interfaces and Dependencies



Nordlys relies on the parties below to deliver the service. Each one is covered by the Supplier Management Policy.

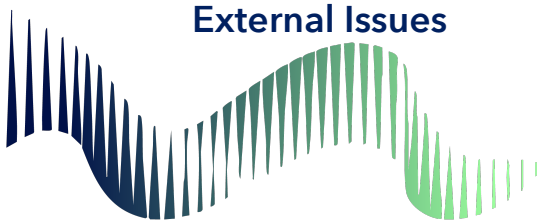
Dependency	What we depend on them for
Amazon Web Services (AWS)	Our own bookkeeping is done by an outside accountant and holds no customer employee data. Handled through supplier management instead.
NordBank Connect (bank and payment file provider)	Takes the payroll payment files the platform generates and passes them on to customers' banks. If a file were altered or leaked, customers could lose money.
VerifyID (Identity and MFA provider)	Handles login and multi-factor authentication for customer administrators.
PeoplePulse Support (helpdesk tool)	Stores customer support tickets, which sometimes contain personal data.
MailRelay EU (email delivery provider)	Sends payslip and notification emails, some of which contain personal data.

Context of the Organization

Internal Issues

- About 85 people and a limited security budget, so effort has to go where the risk is highest.
- Only one engineer fully understands the payment module, and a few others hold similar knowledge of other critical systems.
- Revenue is growing about 25% this year. More customers means more personal data, and pressure to ship features quickly.
- The workforce is largely remote, so laptops, logins and access rights carry a lot of the security load.
- Developers, engineers and HR carry security duties alongside their main work, which makes clear ownership essential.

External Issues



- Payroll data is attractive to criminals. Ransomware, business email compromise and payroll diversion fraud are the main threats.
- More customers are asking for ISO/IEC 27001 in tenders and supplier checks, and some won't buy without it.
- Employee personal data is tightly regulated in the EU and the Nordics, and data protection authorities actively enforce the rules.
- Heavy reliance on a few key suppliers, such as AWS, means a supplier outage or breach directly affects Nordlys' customers.
- New EU rules on cybersecurity and digital services, such as NIS2, are being introduced across Europe, and Nordlys monitors them to see whether they apply.

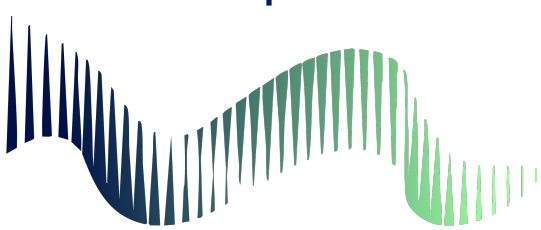
Legal, Regulatory and Contractual Obligations

Obligation	Why it matters for the ISMS
EU General Data Protection Regulation (GDPR)	Nordlys is a data processor for customer employee data. That means appropriate technical and organizational measures, telling customers about breaches without undue delay (so they can meet their own 72-hour deadline to the authority), and helping with data subject requests.
Norwegian Personal Data Act (personopplysningsloven)	Norway's implementation of GDPR, supervised by Datatilsynet.
Accounting and bookkeeping legislation	Sets how long payroll and accounting records must be kept. The Data Retention and Disposal Policy have to match.
Customer contracts and data processing agreements	Set out security commitments, breach notification timelines, audit rights and service levels.
Supplier terms (including AWS)	Define shared responsibility and acceptable use of cloud services

Interested Stakeholders

Stakeholder	Role and Expectation
Data Protection Officer (DPO)	Advises on GDPR, data subject requests and personal data breach notifications.
Head of Peoople	Makes sure security duties are covered at onboarding and tells IT when someone leaves or changes role.
Software Developers	Build and maintain the platform using secure development practices.
Infrastructure and DevOps Engineers	Run the AWS infrastructure, network configuration, access controls and uptime.
Customers (Employers)	Want a reliable service, protection of their employee data and prompt notice of breaches. Some require ISO/IEC 27001.
Customers' employees (data subjects)	Expect their personal and salary data to stay confidential and be correct.
Data protection authority (Datatilsynet)	Supervises GDPR compliance and expects personal data breaches to be reported on time.
AWS and other suppliers	Provide services under agreed terms and expect Nordlys to cover its side of the shared responsibility.
Certification body and auditors	Assess conformity to ISO/IEC 27001 and expect documented evidence.

Scope Maintenance



The scope is reviewed at least once a year, and whenever there is a significant change to the service, hosting environment, locations, suppliers or legal obligations. The ISMS steering group (CEO, CTO, CFO, Head of Security & Compliance and DPO) considers the scope at its quarterly meetings. Any change is approved by the CEO and recorded in the document control table.

